

Autenticazione di rete enterprise con 802.1X, RADIUS e LDAP

Concetti base

Come caso d'uso nella parte iniziale usiamo il wifi ma i concetti sono totalmente generali, assolutamente NON limitati al WIFI

Autenticazione

L'autenticazione serve a verificare l'identità di un utente o dispositivo.

Esempi:

- username e password;
- certificato digitale;
- smart card;
- token.

Autorizzazione

L'autorizzazione stabilisce quali risorse siano accessibili (e anche quali operazioni possiamo effettuare su di esse).

Esempio:

- uno studente può accedere solo alla VLAN studenti;
- un docente può accedere ai server interni.

Accounting

L'accounting consiste nella registrazione delle attività.

Esempi:

- orario di accesso;
- quantità di traffico;
- indirizzo IP assegnato.

Reti Wi-Fi domestiche

Nelle reti domestiche normalmente si utilizza:

- WPA2 Personal;
- WPA3 Personal.

In questi casi tutti **condividono la stessa password**.

Problemi:

- difficile revocare un singolo utente;
- impossibile distinguere gli utenti;
- scarsa tracciabilità;
- maggiore rischio di diffusione della password.

Reti Wi-Fi enterprise

Nelle reti enterprise ogni utente possiede **credenziali individuali**.

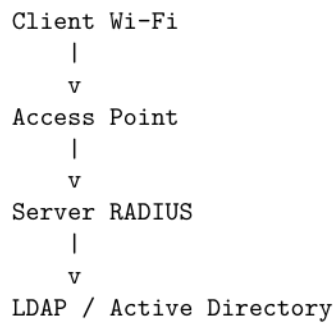
Vantaggi:

- autenticazione centralizzata;
- controllo utenti;
- logging;
- segmentazione della rete;
- revoca utenti singoli.

Schema

RADIUS è un protocollo, non il nome di un server.

Usiamo il termine server RADIUS per indicare un server in grado di interagire usando il protocollo RADIUS.



Sezione 2 — WPA Personal e WPA Enterprise

Overview

Le reti Wi-Fi moderne utilizzano standard WPA2 o WPA3.

WPA Personal

Utilizza:

- PSK (**P**re-**S**hared **K**ey);
- password condivisa.

Normalmente non è utilizzato un server centrale.

Limiti

- nessuna identità individuale (ovvio, si usa solo una chiave, uguale per tutti);
- difficile gestione utenti;
- cambio password necessario per tutti;
- limitata scalabilità.

WPA Enterprise

Usa:

- 802.1X;
- RADIUS;
- EAP.

Ogni utente usa credenziali **personali**.

- 802.1X controlla l'accesso alla rete;
- EAP definisce **il modo** in cui avviene l'autenticazione;
- RADIUS **trasporta** le informazioni di autenticazione, autorizzazione e accounting **fra access point e server**;
- WPA2 Enterprise o WPA3 Enterprise applicano questi meccanismi alla rete Wi-Fi.

Client | | 802.1X / EAP v Access Point | | RADIUS v Server RADIUS

Differenze principali

Caratteristica	WPA Personal	WPA Enterprise
Password condivisa	sì	no
Utenti individuali	no	sì
Server RADIUS	no	sì
Logging utenti	limitato	avanzato
VLAN dinamiche	no	sì
Sicurezza	media	elevata

WPA3

WPA3 migliora:

- robustezza crittografica;
- protezione contro attacchi offline;
- sicurezza handshake.

Due versioni:

- WPA3 Personal;
 - WPA3 Enterprise.
-

Sezione 3 — Standard IEEE 802.1X

Overview

802.1X è uno standard IEEE per il controllo degli accessi di rete.

Serve a consentire l'**accesso solo dopo autenticazione**.

Componenti

Supplicant

È il client che richiede accesso. Esempi: notebook, smartphone, PC, stampanti.

Authenticator

È il dispositivo che controlla l'accesso.

Esempi:

- switch;
- access point.

Authentication Server È il server che autentica. Nel nostro caso normalmente sarà un server RADIUS.

Supplicant

|

| EAPOL

v

Authenticator

|

| RADIUS

v

Authentication Server

EAPOL

EAPOL significa: **EAP** over **LAN**

È il protocollo usato fra client e switch/access point.

Stati della porta

Una porta 802.1X può essere:

- authorized;
- unauthorized.

Se unauthorized:

- passa solo traffico EAPOL.

Se authorized:

- passa traffico normale.

Sequenza semplificata

1. client collegato
2. porta bloccata
3. richiesta autenticazione
4. inoltro a RADIUS
5. verifica credenziali
6. autorizzazione accesso

Vantaggi

- sicurezza maggiore;
- autenticazione centralizzata;
- controllo accessi;
- logging.

Limiti

- maggiore complessità;
- necessità di server dedicati;
- configurazione più difficile.

4 — RADIUS e AAA

Overview

RADIUS è il **protocollo** più usato per gestire autenticazione, autorizzazione e accounting nelle reti.

Nel caso di WPA Enterprise, RADIUS non sostituisce EAP.

Più precisamente:

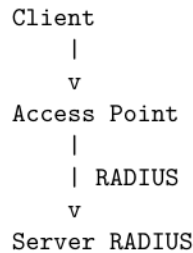
- il client usa un metodo EAP;
- l'access point **incapsula i messaggi EAP dentro richieste RADIUS**;
- il server RADIUS verifica le credenziali o i certificati, **eventualmente interrogando LDAP o Active Directory**;
- il server RADIUS restituisce all'access point l'esito dell'autenticazione e gli eventuali parametri di autorizzazione.

AAA

AAA: Authentication; Authorization; Accounting. - Authentication: Verifica identità. Esempio: username/password.

- Authorization: Definisce permessi. Esempio: assegnazione VLAN.

- Accounting: Registra attività. Esempio: tempo di connessione.



Protocollo RADIUS, concetti base

RADIUS è un protocollo applicativo AAA usato principalmente fra:

- access point o switch;
- server di autenticazione.

Non trasporta direttamente il traffico utente ma **messaggi di controllo relativi all'autenticazione e autorizzazione**.

Esempi di informazioni contenute nei messaggi:

- username;
- password o dati EAP;
- indirizzo IP del client;
- VLAN assegnata;
- tempo di connessione;
- risultato autenticazione.

Esempi concettuali di messaggi RADIUS:

Access-Request

Richiesta autenticazione inviata dall'AP al server.

Access-Accept

Accesso autorizzato.

Access-Reject

Accesso negato.

Accounting-Start

Inizio registrazione sessione.

Accounting-Stop

Fine sessione.

Porte standard

Funzione	Porta UDP
Authentication	1812
Accounting	1813

Storicamente si trovano anche le porte UDP 1645 e 1646 in configurazioni legacy.

Nelle configurazioni moderne è preferibile usare 1812 e 1813.

Shared Secret

Access point e RADIUS condividono una chiave segreta.

Serve per:

- verificare che access point e server RADIUS condividano una relazione di fiducia;
- proteggere parti sensibili dei pacchetti RADIUS;
- impedire che dispositivi non autorizzati possano inviare richieste RADIUS valide al server.

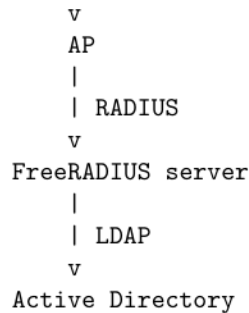
Non sostituisce però TLS o altri meccanismi crittografici usati dai metodi EAP.

Principali server RADIUS

- FreeRADIUS: il server RADIUS open source più diffuso.
- Microsoft NPS
- Cisco ISE.

Flusso

Client
|
| EAPOL



5 — LDAP e Active Directory

Overview

LDAP e Active Directory sono concetti spesso collegati.

LDAP

Lightweight Directory Access Protocol, un protocollo standard.
LDAP da solo non rappresenta un sistema AAA completo.

Serve a:

- cercare utenti;
- leggere attributi;
- verificare credenziali tramite operazioni come il bind LDAP;
- organizzare directory.

LDAP può essere usato da un servizio applicativo, per esempio RADIUS, per verificare credenziali e leggere informazioni sugli utenti.

Un client LDAP può:

- cercare utenti;
- leggere attributi;
- verificare credenziali;
- cercare gruppi;
- modificare alcune informazioni.

Esempi concettuali di operazioni LDAP:

Bind

Tentativo di autenticazione verso il server directory.

Search

Ricerca di utenti o oggetti.

Add

Inserimento di un nuovo oggetto.

Modify

Modifica attributi.

Delete

Eliminazione oggetto.

Esempi di attributi contenuti negli oggetti:

- username;
- email;
- gruppo;
- numero telefonico;
- reparto;
- appartenenza VLAN.

Esempio di Struttura LDAP

Esempio:

```
dc=scuola,dc=local
|
+-- ou=docenti
|
+-- ou=studenti
```

Oggetti LDAP

Ogni oggetto possiede attributi.

Esempi:

- nome;
- email;
- password;
- gruppo;
- telefono.

Active Directory

Active Directory non è semplicemente un server LDAP, è una piattaforma Microsoft per la gestione centralizzata di utenti, computer, autenticazione e risorse di rete.

Active Directory utilizza LDAP, insieme ad altri protocolli e servizi come Kerberos, DNS e Group Policy, e include molte funzionalità enterprise, fra cui:

- directory utenti e gruppi;

- autenticazione centralizzata;
- gestione computer;
- policy di sicurezza;
- gestione domini;
- trust;
- replica;
- integrazione DNS;
- amministrazione centralizzata.

Per la parte Wi-Fi enterprise ci interessa soprattutto il suo ruolo come archivio centralizzato di utenti e gruppi utilizzabile tramite LDAP (e Kerberos, un altro importante protocollo).

LDAP sicuro

Per sicurezza si usa:

- LDAPS;
- StartTLS.

Schema tipico

```
FreeRADIUS
  |
  | LDAP / LDAPS
  v
Active Directory
```

Sezione 6 — Integrazione Wi-Fi Enterprise

Overview

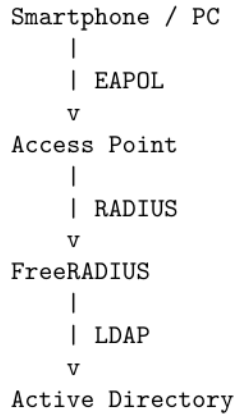
Una rete Wi-Fi enterprise può integrare:

- 802.1X;
- EAP;
- RADIUS;
- LDAP/AD.

Dove:

- 802.1X controlla l'accesso alla rete.
- EAP definisce il metodo di autenticazione.
- RADIUS permette all'access point di comunicare con il server di autenticazione (server RADIUS).
- Servizi directory come Active Directory forniscono directory di utenti, gruppi e attributi, spesso accessibili tramite LDAP.

Architettura



Sequenza dettagliata

- Fase 1
 - il client si collega all'SSID.
- Fase 2
 - l'access point richiede autenticazione 802.1X.
- Fase 3
 - il client e il server avviano lo scambio EAP;
 - a seconda del metodo scelto, lo scambio può usare:
 - * username/password;
 - * certificati;
 - * altri meccanismi di autenticazione.
- Fase 4
 - l'access point non verifica direttamente le credenziali;
 - l'access point incapsula i messaggi EAP in pacchetti RADIUS;
 - i pacchetti vengono inoltrati al server RADIUS.
- Fase 5
 - il server RADIUS verifica credenziali o certificati;
 - se necessario, il server interroga LDAP o Active Directory;
 - la verifica può riguardare:
 - * utenti;
 - * password;
 - * gruppi;
 - * attributi.
- Fase 6
 - se autenticazione corretta:
 - * accesso consentito;
 - altrimenti:
 - * accesso negato.

VLAN dinamiche

Il server RADIUS può assegnare VLAN diverse.

Questa assegnazione viene spesso comunicata all'access point o allo switch tramite attributi RADIUS.

Alcuni attributi usati frequentemente sono:

- **Tunnel-Type**
 - indica il tipo di tunnel o meccanismo utilizzato;
 - nel caso delle VLAN normalmente indica VLAN.
- **Tunnel-Medium-Type**
 - indica il mezzo di trasporto della rete;
 - normalmente Ethernet.
- **Tunnel-Private-Group-ID**
 - contiene l'identificatore della VLAN da assegnare;
 - per esempio VLAN 10 oppure VLAN 20.

In pratica il server RADIUS non si limita a dire “accesso consentito”, ma **può anche indicare in quale VLAN collocare il dispositivo autenticato**.

Esempio:

Gruppo	VLAN
Docenti	10
Studenti	20
Ospiti	30

Benefici

- segmentazione;
- sicurezza;
- gestione centralizzata;
- tracciabilità.

Sezione 6B — Autenticazione nelle reti cablate

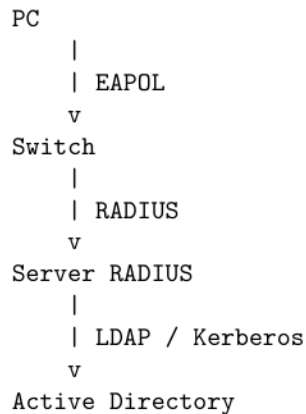
Overview

802.1X, RADIUS, EAP e LDAP non sono tecnologie limitate al Wi-Fi.

Sono ampiamente utilizzate anche nelle reti Ethernet cablate enterprise.

In questo caso il controllo accessi avviene sulle porte dello switch, l'autenticator è normalmente lo switch.

Schema tipico



Funzionamento generale

Fase 1

Il dispositivo viene collegato alla porta Ethernet.

Fase 2

La porta dello switch inizialmente è in stato:

`unauthorized`

Fase 3

Lo switch consente solo traffico EAPOL.

Fase 4

Il client invia credenziali o certificati tramite EAP.

Fase 5

Lo switch inoltra le richieste al server RADIUS.

Fase 6

RADIUS verifica credenziali tramite:

- LDAP;
- Active Directory;
- Kerberos;
- database locali.

Fase 7

Se autenticazione corretta:

- la porta viene autorizzata;
- il traffico normale viene consentito.

Possibili decisioni automatiche

Dopo autenticazione il sistema può:

- assegnare VLAN;
- applicare ACL;
- limitare banda;
- registrare sessioni;
- mettere in quarantena dispositivi non conformi.

Esempi pratici

Scuola

- studenti → VLAN studenti;
- docenti → VLAN docenti;
- segreteria → VLAN amministrativa.

Azienda

- PC aziendali autorizzati → accesso completo;
- dispositivi sconosciuti → rete ospiti o blocco.

Vantaggi della rete cablata autenticata

- maggiore sicurezza fisica e logica;
- riduzione accessi abusivi;
- controllo centralizzato;
- tracciabilità utenti;
- segmentazione automatica.

MAC Authentication Bypass (MAB)

Alcuni dispositivi non supportano 802.1X.

Esempi:

- stampanti;
- telefoni IP;
- telecamere;
- dispositivi IoT.

In questi casi alcuni switch possono usare:

MAC Authentication Bypass

Lo switch invia al server RADIUS il MAC address del dispositivo.

Il server decide:

- autorizzare;
- negare;
- assegnare VLAN specifica.

Limiti

- maggiore complessità amministrativa;
- configurazione switch più complessa;
- necessità di gestione certificati in alcuni casi;
- problemi con dispositivi legacy.

Sezione 7 — Metodi EAP

Overview

EAP definisce diversi metodi di autenticazione.

EAP-TLS

Basato su certificati digitali.

Molto sicuro.

Richiede:

- certificato server;
- certificato client.

PEAP

PEAP crea un tunnel TLS fra client e server.

All'interno del tunnel viene poi eseguita un'autenticazione, spesso basata su username e password.

È molto diffuso in ambienti Windows.

EAP-TTLS

EAP-TTLS crea anch'esso un tunnel TLS.

All'interno del tunnel può trasportare diversi meccanismi di autenticazione, per esempio username e password.

È molto usato con FreeRADIUS e in ambienti misti.

Confronto

Metodo	Sicurezza	Complessità
PEAP	buona	media
EAP-TTLS	buona	media
EAP-TLS	molto elevata	elevata

Certificati

Il certificato server è fondamentale.

Senza verifica certificato:

- rischio rogue access point;
- rischio furto credenziali.

Sezione 8 — VLAN dinamiche e controllo accessi

Overview

RADIUS può assegnare automaticamente VLAN diverse.

Vantaggi

- separazione traffico;
- maggiore sicurezza;
- gestione centralizzata.

Esempio scolastico

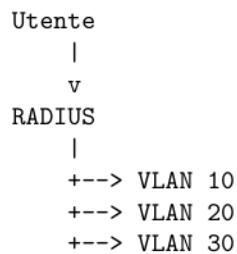
Categoria	VLAN
Laboratorio	10
Docenti	20
Segreteria	30
Ospiti	40

Decisione centralizzata

La decisione può dipendere da:

- gruppo LDAP;
- ruolo;
- certificato;
- dispositivo.

Schema



NAC

802.1X è spesso parte di sistemi NAC (Network Access Control)

Permette:

- controllo dispositivi;
- verifica conformità;
- isolamento sistemi non sicuri.

Sezione 9 — Analisi del traffico e troubleshooting

Overview

Le reti 802.1X possono essere difficili da diagnosticare.

Problemi comuni

- password errata;
- certificato non valido;
- shared secret errata;
- LDAP non raggiungibile;
- orario non sincronizzato.

Strumenti

- Wireshark;
- log FreeRADIUS;
- log access point;
- tcpdump.

Traffico tipico

Protocollo	Uso
EAPOL	client AP

Protocollo	Uso
RADIUS	AP server
LDAP	RADIUS directory

Wireshark

Filtri utili:

`eapol`

oppure:

`radius`

Log FreeRADIUS

Comando:

`freeradius -X`

Avvia FreeRADIUS in modalità debug.

Molto utile per:

- errori autenticazione;
- problemi LDAP;
- problemi certificati.

Sezione 10 — Laboratorio pratico con FreeRADIUS

Overview

Configurazione base di laboratorio.

Obiettivi

Comprendere:

- struttura minima di una soluzione enterprise;
- configurazione base;
- flusso autenticazione.

Ambiente

- Ubuntu Server;
- FreeRADIUS;
- OpenLDAP oppure Active Directory;

- Access point compatibile WPA2 Enterprise.

Installazione FreeRADIUS

Ubuntu:

```
sudo apt update
sudo apt install freeradius
```

Avvio debug

```
sudo freeradius -X
```

Configurazione client RADIUS

File:

```
/etc/freeradius/3.0/clients.conf
```

Esempio:

```
client ap_scuola {
    ipaddr = 192.168.1.2
    secret = segretoRadius
}
```

Utente locale di test

File:

```
/etc/freeradius/3.0/users
```

Esempio:

```
studente1 Cleartext-Password := "Password123"
```

Test locale

Comando:

```
radtest studente1 Password123 localhost 0 testing123
```

Configurazione access point

Configurare:

- modalità WPA2 Enterprise;
- IP server RADIUS;
- porta 1812;
- shared secret.

Collegamento LDAP

Installare modulo LDAP.

Configurare:

- indirizzo server LDAP;
- DN base;
- bind user;
- password bind;
- uso di LDAPS o StartTLS, quando disponibile;
- mapping fra gruppi LDAP/AD e autorizzazioni di rete, se necessario.

Schema finale laboratorio

Notebook

|

v

Access Point

|

v

FreeRADIUS

|

v

LDAP / Active Directory

Verifica

Concetti

- differenza fra WPA Personal e WPA Enterprise;
- ruolo di RADIUS;
- differenza fra LDAP e Active Directory;
- funzione di 802.1X;
- ruolo di EAP;
- significato di AAA.

Attività pratiche

- interpretazione schema di rete;
- identificazione componenti;
- analisi log semplificati;
- progettazione rete scolastica.

Estensioni possibili

- integrazione con VLAN dinamiche;

- autenticazione cablata 802.1X;
- EAP-TLS con certificati;
- NAC avanzato;
- captive portal;
- autenticazione federata.

Glossario

Termine	Significato
AAA	Authentication, Authorization, Accounting
AD	Active Directory
AP	Access Point
EAP	Extensible Authentication Protocol
EAPOL	EAP over LAN
LDAP	Lightweight Directory Access Protocol
NAC	Network Access Control
PSK	Pre-Shared Key
RADIUS	Remote Authentication Dial-In User Service
WPA	Wi-Fi Protected Access
802.1X	Port-based Network Access Control

Alcuni riferimenti

IEEE 802.1X: <https://standards.ieee.org/ieee/802.1X/1096/>

FreeRADIUS: <https://www.freeradius.org/>

FreeRADIUS documentation: <https://wiki.freeradius.org/>

Microsoft NPS: <https://learn.microsoft.com/en-us/windows-server/networking/technologies/nps/nps-top>

LDAP RFC: <https://datatracker.ietf.org/doc/html/rfc4511>

EAP RFC: <https://datatracker.ietf.org/doc/html/rfc3748>

WPA3: <https://www.wi-fi.org/discover-wi-fi/security>